

(a) rules, penalties and thresholds as implemented

fraction of requests the rule fires on $\rightarrow$		legitimate stable	legitimate drift	attack A4
R1	presented key $\neq$ the token's cnf.jkt penalty 0.80 · component: device binding	0.000	0.000	0.000
R2	key or fingerprint unseen for this subject penalty 0.35 · component: device binding	0.000	0.000	1.000
R3	implied geo velocity > 500 km/h penalty 0.60 · component: context	0.038	0.973	0.033
R5	session continuity < 0.50 penalty 0.20 · component: context	0.000	0.000	0.333
R6	DPoP-failure rate > 0.10 penalty 0.20 · component: context	0.000	0.000	0.000
R4	call rate > 30 req/min penalty 0.25 · component: velocity	1.000	1.000	0.300

risk = $\min(1, \Sigma \text{ penalties of the rules that fired})$ **belief b** = $1 - \text{risk}$

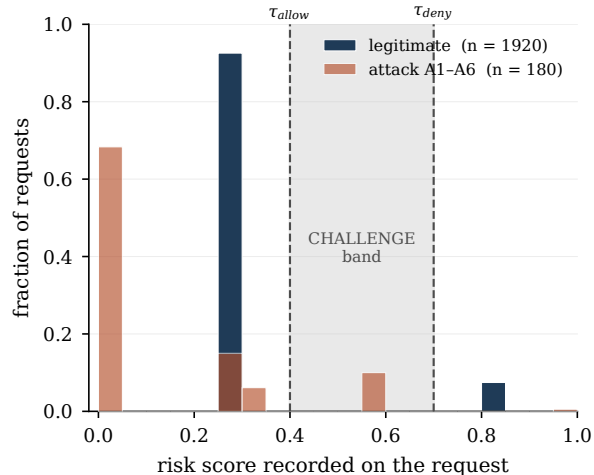
R1 never fires in B1 or P: a thumbprint mismatch is already refused at stage 2.

R6 never crosses its threshold within one reset window.

The rules are deterministic and auditable; nothing is learned.

Bold marks a rule that fires on at least 90% of that population — and therefore carries almost no information about it.

(b) measured risk distribution



The distribution is bimodal and the challenge band is almost never occupied: an additive rule set with six coarse penalties does not produce the graded score that step-up authentication needs.